

CS 578: CYBER-SECURITY

PART I: NETWORK, INTERNET SECURITY – INTERNET PROTOCOLS

Sanghyun Hong

sanghyun.hong@oregonstate.edu



Oregon State
University



TRUE AI
Trustworthy and Responsible AI

ANNOUNCEMENT

- TA office hours
 - Mon 11 am – 12 pm on Zoom (the same link used for online lectures)
- Term-project and in-class presentation sign-up
 - Close on 9/30 (Wed)
 - Presentation slots: first come, first served. No slot = 0 pts
 - No team on the sheet (late forming) = -2% of your term grade

RECAP

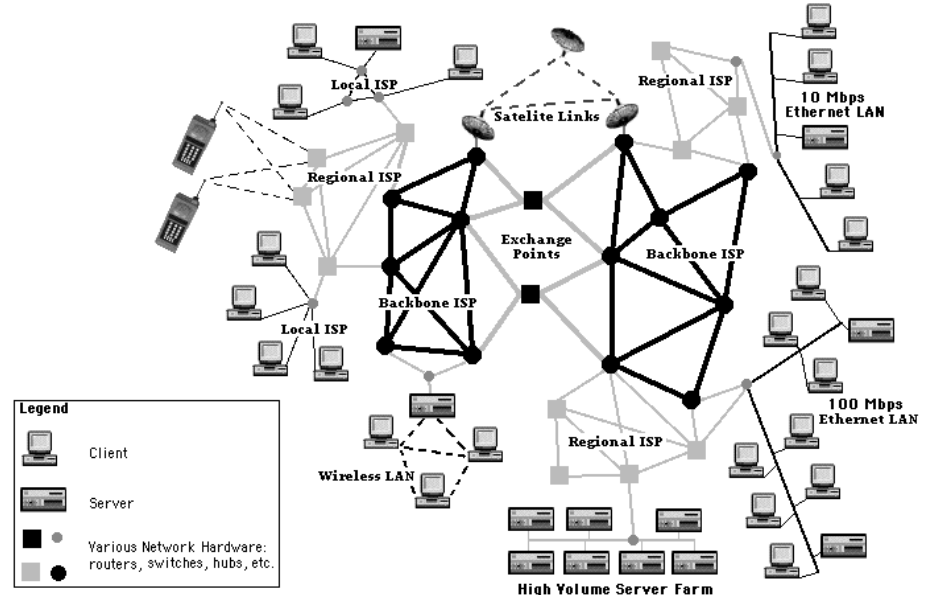
- The security mindset
 - Schneier: How does an adversary think? = How to break it?
 - Anderson: Who will be motivated to fix security problems? = How to set incentives?

TWO MEASUREMENT STUDIES: CENSYS AND MINING YOUR PS AND QS

PRIMER ON THE INTERNET INFRASTRUCTURE

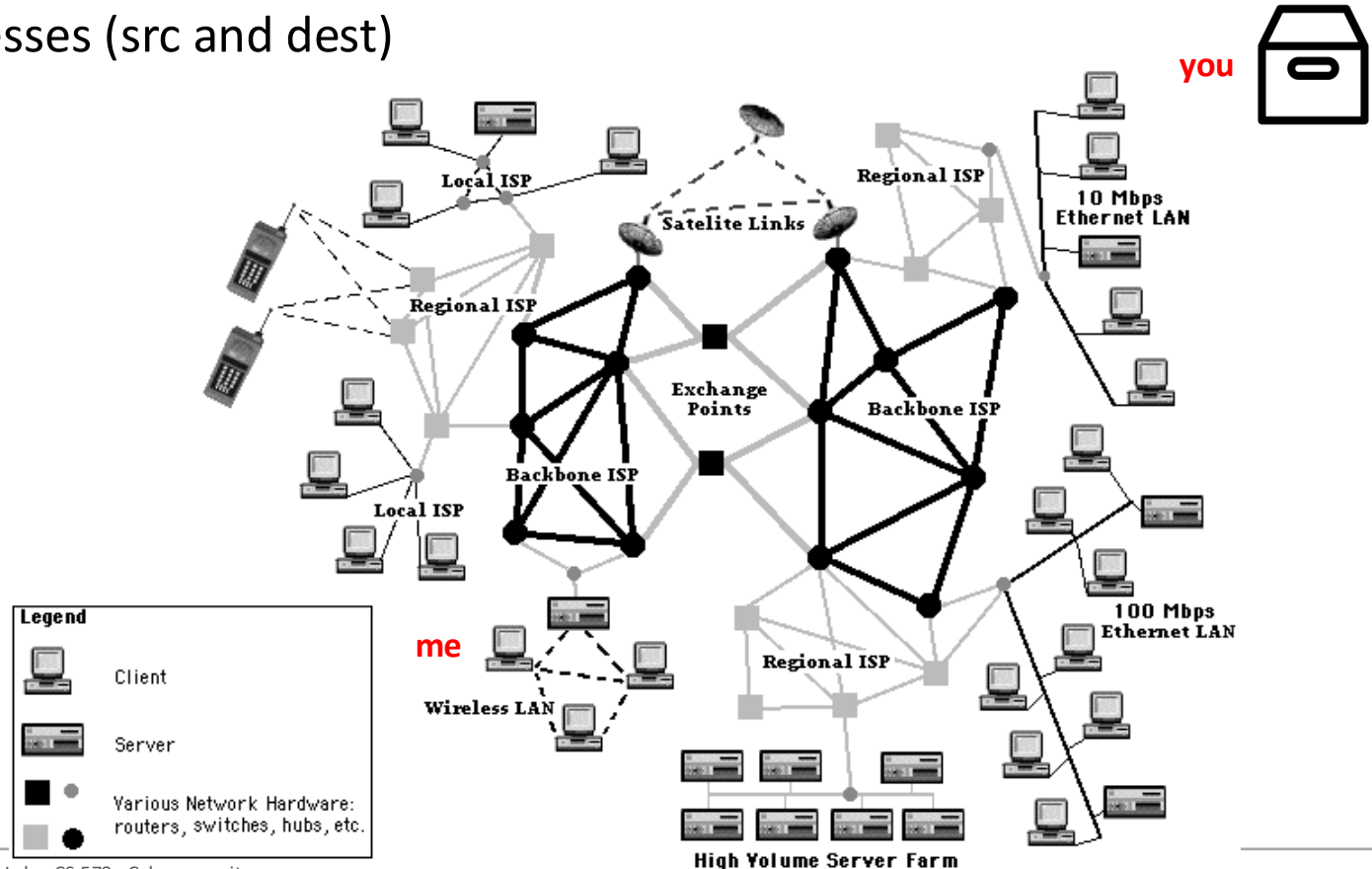
THE INTERNET

- The Net
 - A system of computer networks; a network of networks
 - Uses the Internet protocol suite (TCP/IP) to communicate
- Design principle (in 1970s)
 - Network is complex, $O(N^2)$
 - Manage small network, $O(n^2)$
 - Manage network of networks $O(m^2)$
 - $N \ggggg m, n$
 - **Make it simple!**



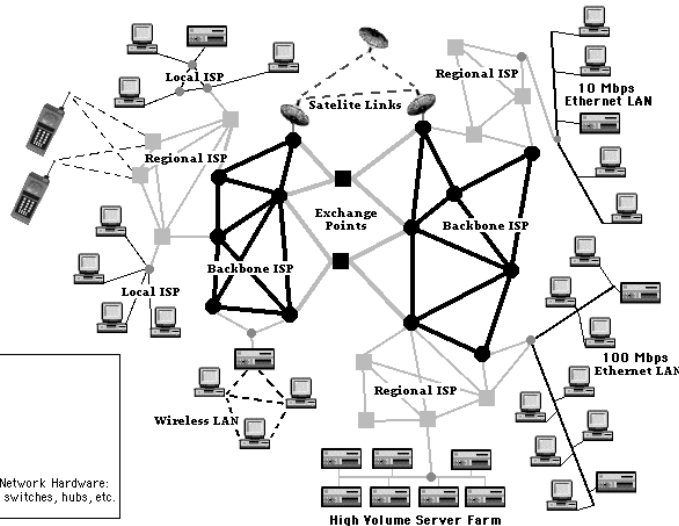
THE INTERNET WAS ABOUT HOW TO ROUTE A PACKET

- IP addresses (src and dest)



THE FIRST PROBLEM IN THE PACKET ROUTING

- No security
 - Any router in the middle can see any packet content :(

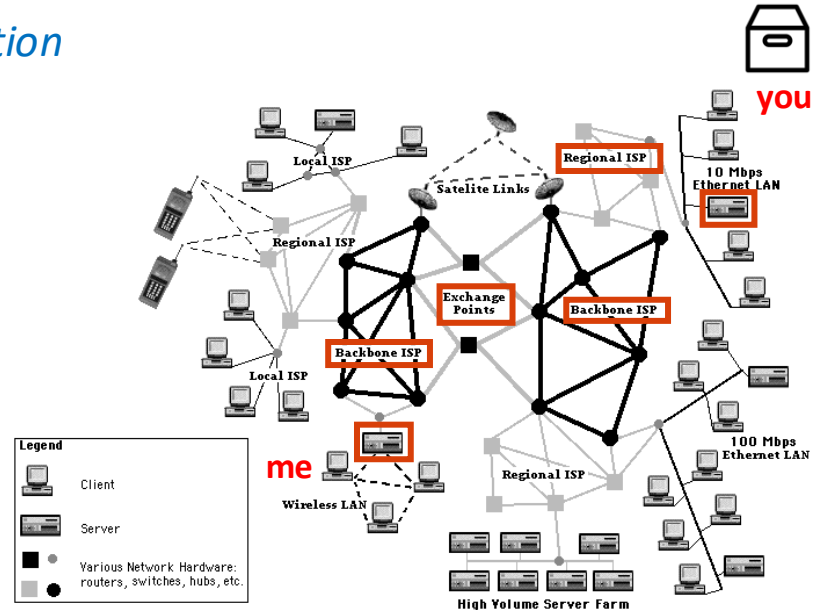


The image shows a Wireshark packet capture window. The top pane displays a list of packets, with packet 129 selected. The middle pane shows the details of the selected packet, which is an HTTP GET request. The bottom pane shows the raw packet data in hexadecimal and ASCII. The packet details include the following fields:

- GET /info?txtAirPlay&txtRAOP_RTSP/1.0
- RTSP/1.0 200 OK
- Date: Tue, 25 Oct 2022 07:19:31 GMT
- Content-Length: 1499
- Content-Type: application/x-apple-binary-plist
- Server: AirTunes/620.8.2
- Content-Disposition: attachment; filename="bplist00....."
- Content-Type: application/x-apple-binary-plist
- Content-Length: 1499
- Content-Type: application/x-apple-binary-plist
- Server: AirTunes/620.8.2

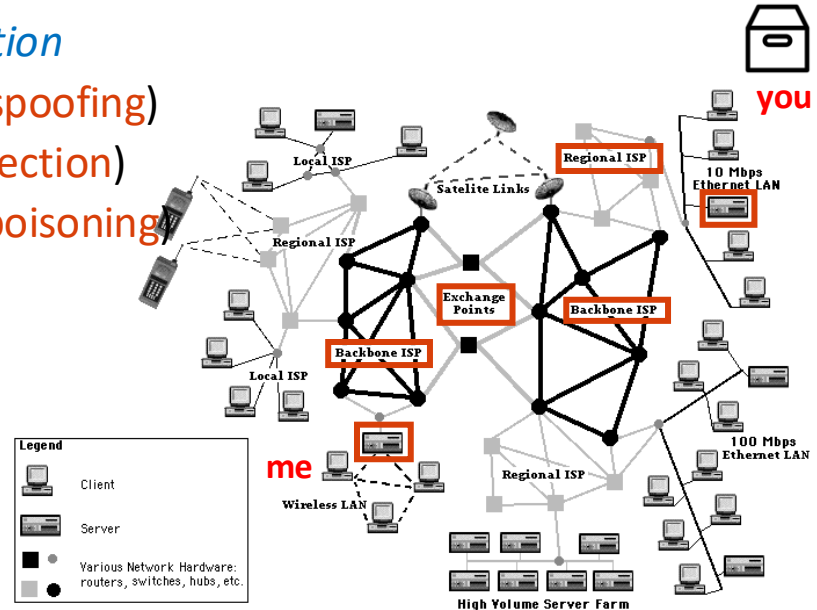
THE INTERNET: NO SECURITY

- Routers:
 - Decide where the packet should go as a next step
- Potential risks
 - *Background: OSI 7-layer, packet encapsulation*



THE INTERNET: NO SECURITY, MORE PROBLEMS

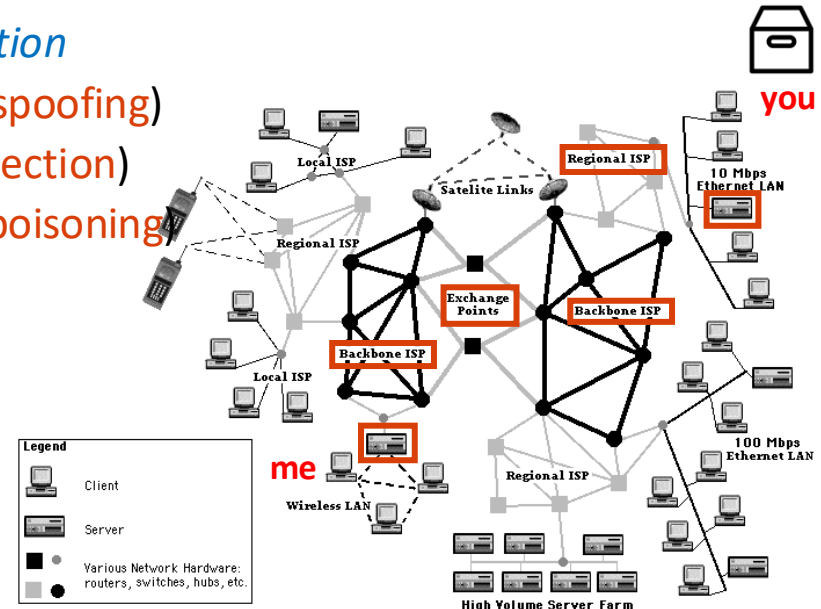
- Routers:
 - Decide where the packet should go as a next step
- Potential risks
 - *Background: OSI 7-layer, packet encapsulation*
 - IP : no auth for the source IP addresses (**spoofing**)
 - TCP : no auth for the packet sequences (**injection**)
 - DNS: no auth for the DNS answers (**cache poisoning**)
 - BGP: no auth for routing paths (**hijacking**)



THE INTERNET: NO SECURITY, MORE PROBLEMS

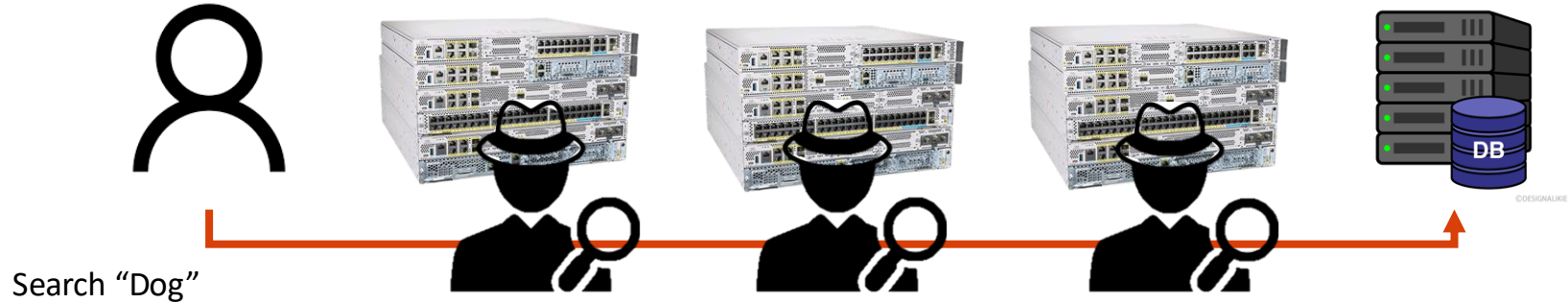
- Routers:
 - Decide where the packet should go as a next step
- Potential risks
 - *Background: OSI 7-layer, packet encapsulation*
 - IP : no auth for the source IP addresses (**spoofing**)
 - TCP : no auth for the packet sequences (**injection**)
 - DNS: no auth for the DNS answers (**cache poisoning**)
 - BGP: no auth for routing paths (**hijacking**)
- Let's establish trust in routers
 - Anderson's: who's motivated to fix this?

We Cannot Establish Trust in Routers



PRIMER ON **SECURING** THE INTERNET INFRASTRUCTURE

THE FIRST PROBLEM: PLAINTEXT PACKETS

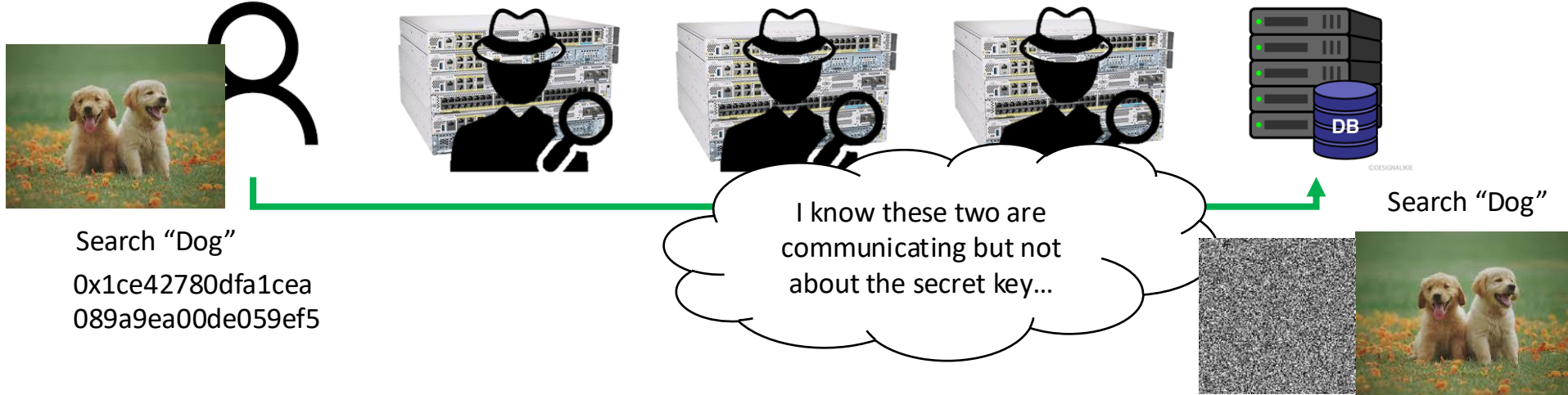


**Everybody in the Middle Knows That I Searched 'dogs'
and They Also Know the Search Result... Ugh...**

THE SOLUTION FOR THE FIRST PROBLEM: SSL, TLS

Middle men never know
DH exchange keys!!

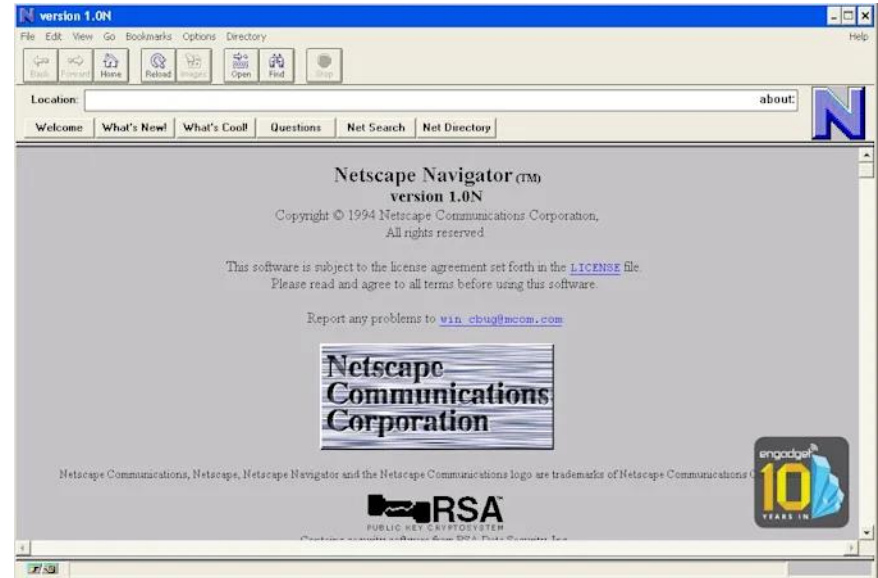
Check certificate, exchange keys, apply encryption with HMAC



The Middlemen Will Only See the Encrypted Contents
They Will **Never Know the Secret Key ...**

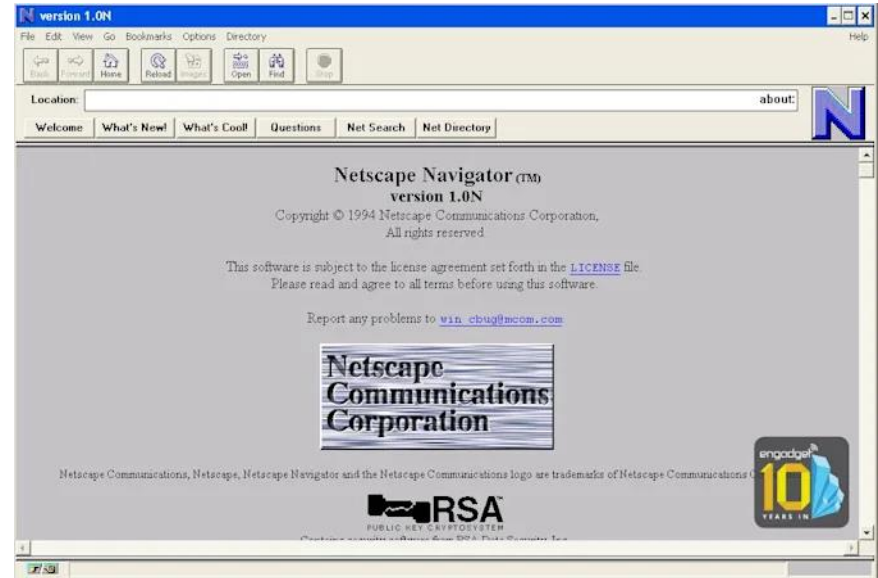
SSL/TLS: SECURE SOCKET LAYER AND TRANSPORT LAYER SECURITY

- SSL/TLS
 - Developed by Netscape in 1995
 - Standardized by IETF as TLS
 - <https://www.ietf.org/rfc/rfc2246.txt>



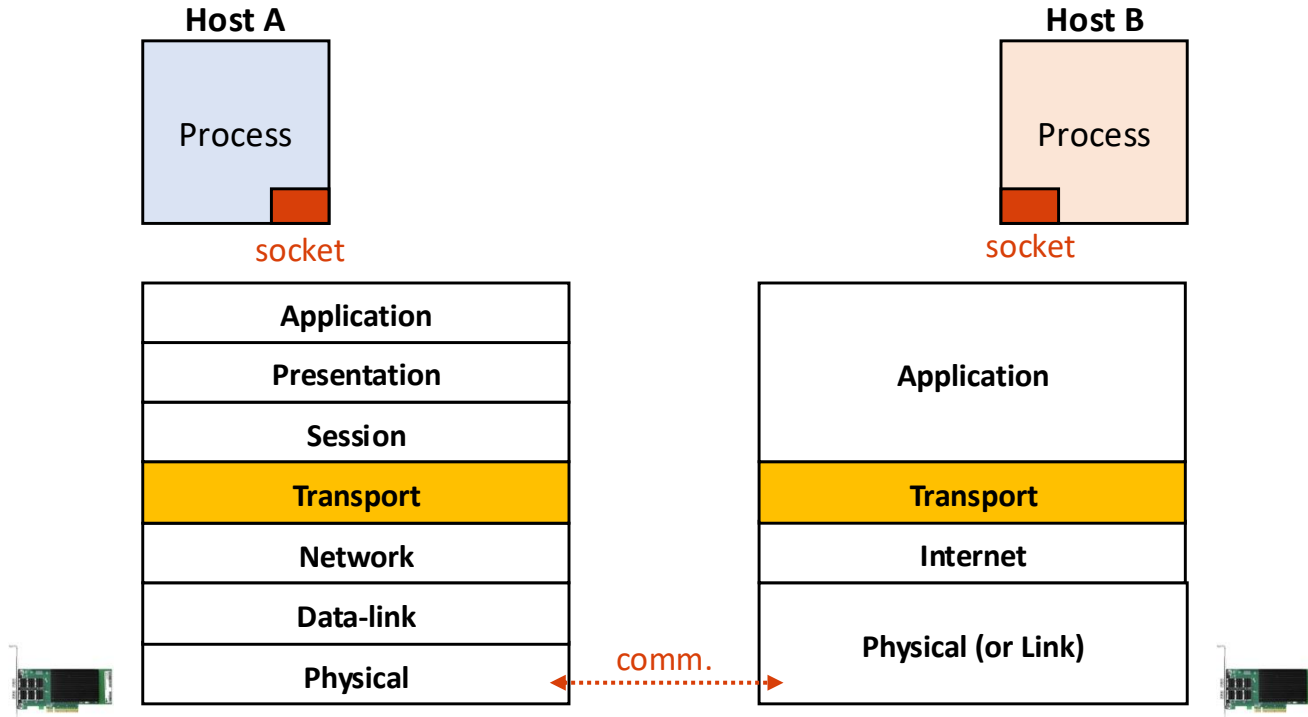
SSL/TLS: SECURE SOCKET LAYER AND TRANSPORT LAYER SECURITY

- SSL/TLS
 - Developed by Netscape in 1995
 - Standardized by IETF as TLS
 - <https://www.ietf.org/rfc/rfc2246.txt>
- “Transport Layer” Security
 - Why?



SSL/TLS: TRANSPORT LAYER SECURITY, WHY?

- Independent from the application running on a host



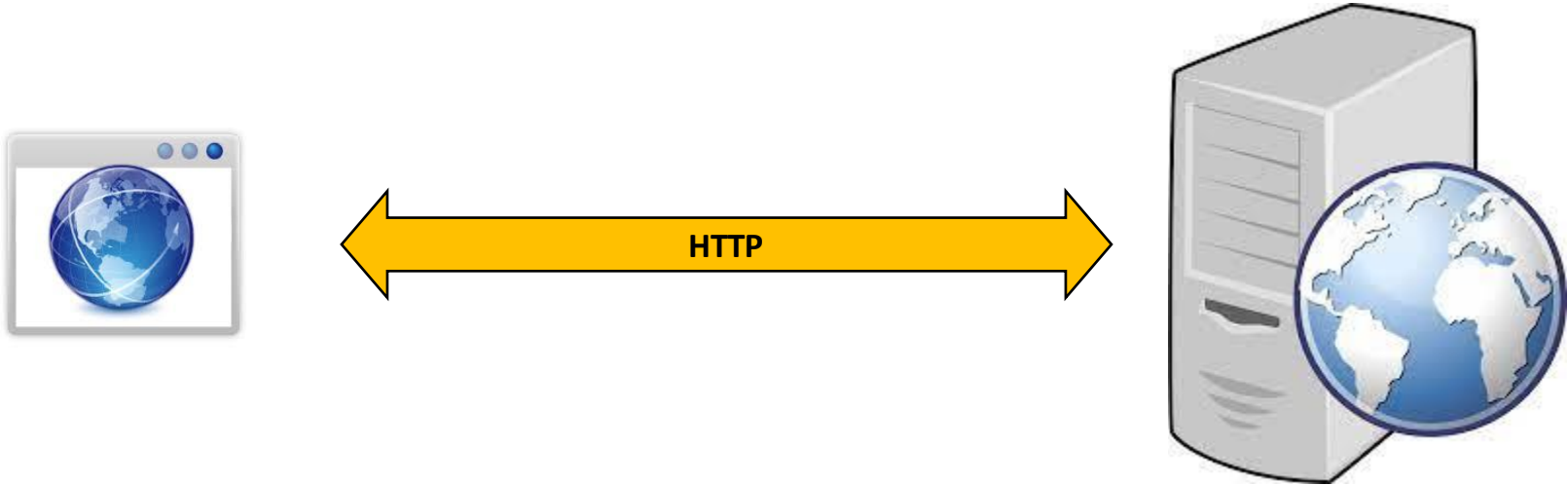
SSL/TLS: BENEFITS

- Enable to
 - Establish secure comm channels btw two ends (hosts) on the Internet
 - Client <-> Server (ex. OSU login)
 - Server <-> Server (ex. Amazon requests a transaction with your credit card)
 - Client <-> Client (ex. chat applications)
 - Verify the server entity
 - Use a digital certificate
- end-to-end secure communication channels
 - Authentication: a digital certificate
 - Key-exchange: Diffie-Hellman key exchange
 - Confidentiality: Block ciphers
 - Integrity: HMAC / MAC

AN EXAMPLE: HTTP VS. HTTPS

HTTP: AN APPLICATION LAYER PROTOCOL

- Suppose we talk to a webserver



HTTP: AN APPLICATION LAYER PROTOCOL

- Suppose we talk to a webserver



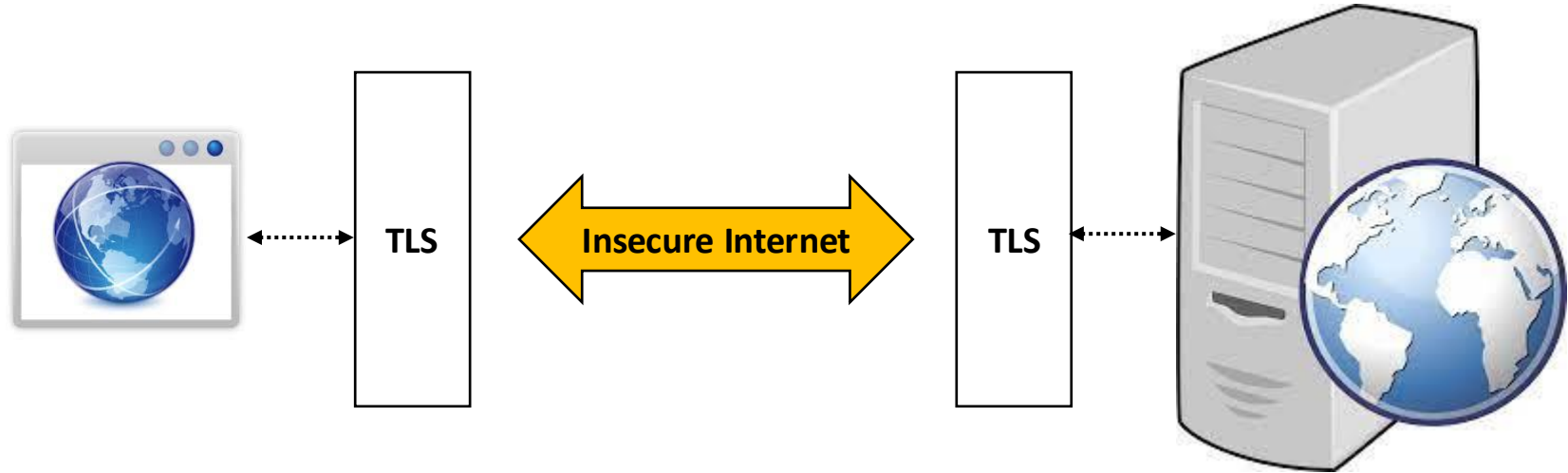
```
GET / HTTP/1.0
```



```
HTTP/1.0 200 OK
Date: Tue, 25 Oct 2022 12:53:12 GMT
Expires: -1
Cache-Control: private, max-age=0
Content-Type: text/html; charset=ISO
P3P: CP="This is not a P3P policy! S
Server: gws
X-XSS-Protection: 0
X-Frame-Options: SAMEORIGIN
```

HTTPS: AN APPLICATION LAYER (SECURE) PROTOCOL

- Suppose we use HTTPs (instead of HTTP)



HTTPS: AN APPLICATION LAYER (SECURE) PROTOCOL

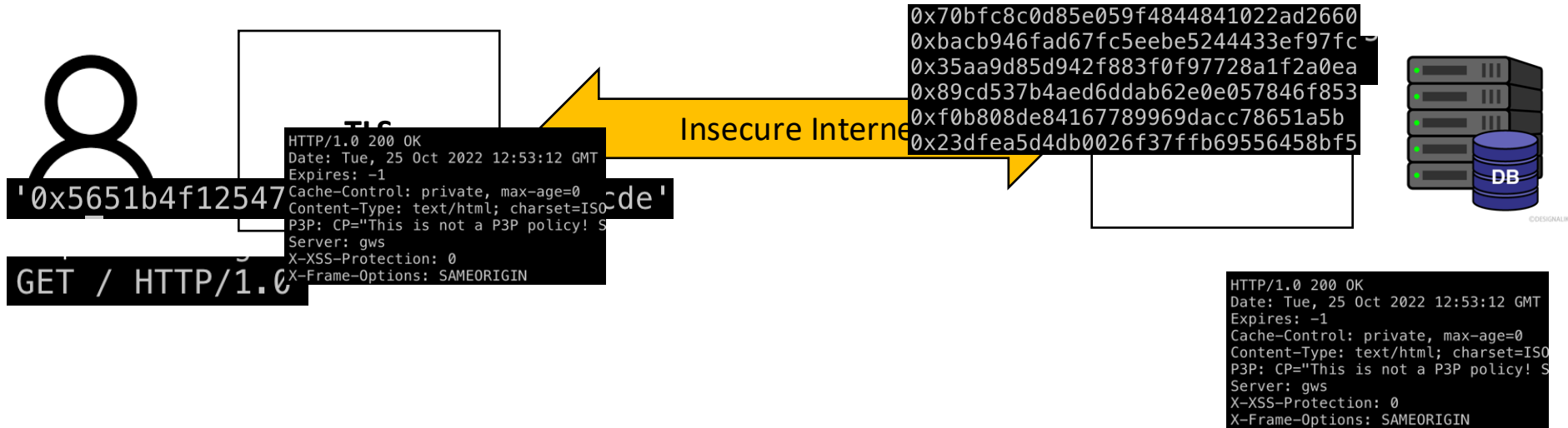


Run **TLS handshake** to establish a secure channel



©DESIGNAUXIE

HTTPS: AN APPLICATION LAYER (SECURE) PROTOCOL



LET'S SEE HOW HTTP PACKETS LOOK LIKE

4 0.010756057 10.248.25.87 142.250.69.196 HTTP 144 GET / HTTP/1.1

```
GET / HTTP/1.1
Host: www.google.com
User-Agent: curl/7.81.0
Accept: */*

HTTP/1.1 200 OK
Date: Tue, 25 Oct 2022 13:25:43 GMT
Expires: -1
Cache-Control: private, max-age=0
Content-Type: text/html; charset=ISO-8859-1
P3P: CP="This is not a P3P policy! See g.co/p3phelp for more info."
Server: gws
X-XSS-Protection: 0
X-Frame-Options: SAMEORIGIN
Set-Cookie: 1P_JAR=2022-10-25-13; expires=Thu, 24-Nov-2022 13:25:43 GMT; path=/; domain=.google.com; Secure
Set-Cookie: AEC=AakniGOAPvX70HdR0vGjd5tdhzmMk-ZntDxb9jZGhAdPNSmqmwQc2AumLRI; expires=Sun, 23-Apr-2023 13:25:43 GMT; path=/; domain=.google.com; Secure; HttpOnly; SameSite=lax
Set-Cookie: NID=511=MkIeDpP817QKD-9oufZM9-
MANHF1DpvagPc6jwK6L-2onKyCQID83aSymrg5ss1SUexUDPaSsNb9MrcxpnaXhezC9engEZrNmX4ggoG7Zodt4Fy-
HP9FQI6DbeY6GLGCaMB0nUmze5m6Ys-16jSvC6WFJukye67i0SgFuG72c; expires=Wed, 26-Apr-2023 13:25:43 GMT; path=/; domain=.google.com; HttpOnly
Accept-Ranges: none
Vary: Accept-Encoding
Transfer-Encoding: chunked

348f
<!doctype html><html itemscope="" itemtype="http://schema.org/WebPage" lang="en"><head><meta
content="Search the world's information, including webpages, images, videos and more. Google has many
special features to help you find exactly what you're looking for." name="description"><meta
content="noodp" name="robots"><meta content="text/html; charset=UTF-8" http-equiv="Content-Type"><meta
content="/images/branding/googleg/1x/googleg_standard_color_128dp.png" itemprop="image"><title>Google</
title><script nonce="zhUe3NfmQtn_Ha4HtJ5i3A">(function(){window.google={KEI:'1-
NXY8iGIs2T0PEP5fy9CA',kEXPI:'0,18167,1284369,56873,6059,206,4804,2316,383,246,5,5367,1123753,1197698,703
,302561,77529,16114,19398,9286,22431,1361,284,12036,17579,4998,13228,3847,6885,3737,22741,5001,1594,1278
,2742,149,1943,1983,214,4100,109,3405,606,2023,1777,520,14670,605,2622,2845,7,4800,791,28171,1851,2614,1
2710,432,3,1590,1,5444,149,11323,2652,4,1528,2304,7039,22023,5708,7356,16639,16800,1435,5827,2530,4094,1
7,4035,3,3541,1,14263,27894,2,14019,2373,342,4931,6470,9868,1755,5679,1021,2380,22668,6074,4568,6258,234
18,1252,5835,14968,4332,2204,5280,445,2,2,1,10956,15676,8155,7381,2,3,15965,873,6577,3048,10007,9,1921,5
784,3995,19130,12192,4832,17016,122,700,4,1,2,2,2,2,8652,107,821,4337,785,1765,978,3023,2756,3546,2,2017
,14,82,950,1758,168,1014,751,202,1866,125,6416,1,1015,51,2197,488,922,613,1323,346,109,364,466,683,899,2
,307,37,1520,450,10,000,00,374,364,3347,053,1063,1330,33,3,5,050,343,37,431,140,13,1,023,3000,1206,004,00
Packet 4, 1 client pkt, 0 server pkts, 1 turn. Click to select.
```

LET'S SEE HOW HTTPS PACKETS LOOK LIKE

```
40 4.482276498 10.248.25.87 142.250.69.196 TLSv1... 146 Change Cipher Spec, Application Data
> Frame 40: 146 bytes on wire (1168 bits), 146 bytes captured (1168 bits) on interface wlp0s20f3, id 0
> Ethernet II, Src: IntelCor_6c:c3:5c (98:2c:bc:6c:c3:5c), Dst: IETF-VRRP-VRID_01 (00:00:5e:00:01:01)
> Internet Protocol Version 4, Src: 10.248.25.87, Dst: 142.250.69.196
> Transmission Control Protocol, Src Port: 44148, Dst Port: 443, Seq: 518, Ack: 4303, Len: 80
< Transport Layer Security
  > TLSv1.3 Record Layer: Change Cipher Spec Protocol: Change Cipher Spec
  < TLSv1.3 Record Layer: Application Data Protocol: http-over-tls
    Opaque Type: Application Data (23)
    Version: TLS 1.2 (0x0303)
    Length: 69
    Encrypted Application Data: 8684730f1612223931bb38393d0213d0b0e0dd0aa2ea6b908fab28f13c4ef8f8beba27d2...
    [Application Data Protocol: http-over-tls]

0000 00 00 5e 00 01 01 98 2c bc 6c c3 5c 08 00 45 00 ..^.... .l.\..E.
0010 00 84 73 f7 40 00 40 06 cd 6f 0a f8 19 57 8e fa ..s-@-@- .o-..W..
0020 45 c4 ac 74 01 bb de 97 e7 2a d2 93 69 1c 80 18 E..t.... *..i...
0030 01 f5 f9 83 00 00 01 01 08 0a 09 e8 fa 1d 62 2d .....b-
0040 cc 7d 14 03 03 00 01 01 17 03 03 00 45 86 84 73 .}.....E..s
0050 0f 16 12 22 39 31 bb 38 39 3d 02 13 d0 b0 e0 dd ..."91.8 9=.....
0060 0a a2 ea 6b 90 8f ab 28 f1 3c 4e f8 f8 be ba 27 ...k...(<N....'
0070 d2 67 e8 e4 2e 71 28 62 13 11 7d fb a1 58 fc 0c .g...q(b ..}..X..
0080 1d 5b da 7c 91 3f 6d 9f bb 1d 6c 0b 67 ce 18 23 .[.|.?m. .l.g..#
0090 b9 d8 ..
```

00000000 16 03 01 02 00 01 00 01 fc 03 03 cb 6c ea fb 9fl...
00000010 71 f0 1d 41 6a 19 4d 76 10 3b 3a e2 eb e5 1d 63 q..Aj.Mv .;:....c
00000020 92 d2 da d2 d2 46 98 73 16 b6 75 20 f8 43 a8 ebF.s ..u .C..
00000030 05 41 47 7e 53 47 37 ad 39 78 32 5a f7 88 ae c1 .AG~SG7. 9x2Z....
00000040 64 77 d6 51 e6 e4 ac ef 03 26 6a a2 00 3e 13 02 dw.Q....&j..>..
00000050 13 03 13 01 c0 2c c0 30 00 9f cc a9 cc a8 cc aa0
00000060 c0 2b c0 2f 00 9e c0 24 c0 28 00 6b c0 23 c0 27 .+./...\$.(.k.#.'
00000070 00 67 c0 0a c0 14 00 39 c0 09 c0 13 00 33 00 9d .g.....93..
00000080 00 9c 00 3d 00 3c 00 35 00 2f 00 ff 01 00 01 75 ...=<.5 ./.....u
00000090 00 00 00 13 00 11 00 00 0e 77 77 77 2e 67 6f 6fwww.goo
000000A0 67 6c 65 2e 63 6f 6d 00 0b 00 04 03 00 01 02 00 gle.com.
000000B0 0a 00 16 00 14 00 1d 00 17 00 1e 00 19 00 18 01
000000C0 00 01 01 01 02 01 03 01 04 33 74 00 00 00 10 003t....
000000D0 0e 00 0c 02 68 32 08 68 74 74 70 2f 31 2e 31 00h2.h ttp/1.1.
000000E0 16 00 00 00 17 00 00 00 31 00 00 00 0d 00 2a 001.....*.
000000F0 28 04 03 05 03 06 03 08 07 08 08 08 09 08 0a 08 (.
00000100 0b 08 04 08 05 08 06 04 01 05 01 06 01 03 03 03
00000110 01 03 02 04 02 05 02 06 02 00 2b 00 05 04 03 04+.
00000120 03 03 00 2d 00 02 01 01 00 33 00 26 00 24 00 1d ...~....3.&\$.
00000130 00 20 31 6b 2c 95 bb 6c 06 fb 83 c0 b9 82 1d ee . 1k,..l
00000140 5f 85 0c da 5c 31 9d b6 dc 00 72 d5 06 08 90 d4 _...\\1.. ..r.....
00000150 85 60 00 15 00 af 00 00 00 00 00 00 00 00 00 00
00000160 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
00000170 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
00000180 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
00000190 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
000001A0 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
000001B0 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
000001C0 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
000001D0 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
000001E0 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
000001F0 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
00000200 00 00 00 00 00
.....

00000000 16 03 03 00 7a 02 00 00 76 03 03 82 f4 4b ce 9fz... v....K..
00000010 b3 46 18 0f 31 0b 53 1f 4d a0 e6 17 07 3a 83 f6 .F..1.S. M....:..
00000020 06 c0 4c a2 eb 2c a3 6f b3 c2 f8 20 f8 43 a8 eb ..L...oC..
00000030 05 41 47 7e 53 47 37 ad 39 78 32 5a f7 88 ae c1 .AG~SG7. 9x2Z....
00000040 64 77 d6 51 e6 e4 ac ef 03 26 6a a2 13 02 00 00 dw.Q....&j.....
00000050 2e 00 33 00 24 00 1d 00 20 85 51 b9 c0 6e b7 59 ..3.\$....Q..n.Y
00000060 4e 79 54 6a dc f5 c2 5b 7d 0b 5e 59 a7 50 a4 37 NyTj...[}.^Y.P.7
00000070 58 20 c8 6a d6 58 7b 3d 00 2b 00 02 03 04 14 X .j.X}U 1+.....
00000080 83 83 83 83 83 83 83 83 83 83 83 83 83 83 83
00000090 83 83 83 83 83 83 83 83 83 83 83 83 83 83 83
000000A0 83 83 83 83 83 83 83 83 83 83 83 83 83 83 83
000000B0 83 83 83 83 83 83 83 83 83 83 83 83 83 83 83
000000C0 83 83 83 83 83 83 83 83 83 83 83 83 83 83 83
000000D0 83 83 83 83 83 83 83 83 83 83 83 83 83 83 83
000000E0 83 83 83 83 83 83 83 83 83 83 83 83 83 83 83
000000F0 83 83 83 83 83 83 83 83 83 83 83 83 83 83 83
00000100 83 83 83 83 83 83 83 83 83 83 83 83 83 83 83
00000110 83 83 83 83 83 83 83 83 83 83 83 83 83 83 83
00000120 83 83 83 83 83 83 83 83 83 83 83 83 83 83 83
00000130 83 83 83 83 83 83 83 83 83 83 83 83 83 83 83
00000140 83 83 83 83 83 83 83 83 83 83 83 83 83 83 83
00000150 83 83 83 83 83 83 83 83 83 83 83 83 83 83 83
00000160 83 83 83 83 83 83 83 83 83 83 83 83 83 83 83
00000170 83 83 83 83 83 83 83 83 83 83 83 83 83 83 83
00000180 83 83 83 83 83 83 83 83 83 83 83 83 83 83 83
00000190 83 83 83 83 83 83 83 83 83 83 83 83 83 83 83
000001A0 83 83 83 83 83 83 83 83 83 83 83 83 83 83 83
000001B0 83 83 83 83 83 83 83 83 83 83 83 83 83 83 83
000001C0 83 83 83 83 83 83 83 83 83 83 83 83 83 83 83
000001D0 83 83 83 83 83 83 83 83 83 83 83 83 83 83 83
000001E0 83 83 83 83 83 83 83 83 83 83 83 83 83 83 83
000001F0 83 83 83 83 83 83 83 83 83 83 83 83 83 83 83
00000200 83 83 83 83 83 83 83 83 83 83 83 83 83 83 83
.....

Application Data

id 0
01)

8beba27d2...

00000000 16 03 01 02 00 01 00 01 fc 03 03 cb 6c ea fb 9f
00000010 71 f0 1d 41 6a 19 4d 76 10 b6 3a e2 eb e5 1d 63
00000020 92 d2 da d2 d2 46 98 73 16 b6 75 20 f8 43 a8 eb
00000030 05 41 47 7e 53 47 37 ad 39 78 32 5a f7 88 ae c1
00000040 64 77 d6 51 e6 e4 ac ef 03 26 6a a2 00 3e 13 02
00000050 13 03 13 01 c0 2c c0 30 00 9f cc a9 cc a8 cc aa
00000060 c0 2b c0 2f 00 9e c0 24 c0 28 00 6b c0 23 c0 27
00000070 00 67 c0 0a c0 14 00 39 c0 09 c0 13 00 33 00 9d
00000080 00 9c 00 3d 00 3c 00 35 00 2f 00 ff 01 00 01 75
00000090 00 00 00 13 00 11 00 00 0e 7f 77 77 2e 67 6f 6f
000000A0 67 6c 65 2e 63 6f 6d 00 0b 00 04 03 00 01 02 00
000000B0 0a 00 16 00 14 00 1d 00 17 00 1e 00 19 00 18 01
000000C0 00 01 01 01 02 01 03 01 04 33 74 00 00 00 10 00
000000D0 0e 00 0c 02 68 32 08 68 74 74 70 2f 31 2e 31 00
000000E0 16 00 00 00 17 00 00 00 31 00 00 00 0d 00 2a 00
000000F0 28 04 03 05 03 06 03 08 07 08 08 08 09 08 0a 08
00000100 0b 08 04 08 05 08 06 04 01 05 01 06 01 03 03 03
00000110 01 03 02 04 02 05 02 06 02 00 2b 00 05 04 03 04
00000120 03 03 00 2d 00 02 01 01 00 33 00 26 00 24 00 1d
00000130 00 20 31 6b 2c 95 1b 6c 06 fb 83 c0 b9 82 1d ee
00000140 5f 85 0c da 5c 31 9d b6 dc 00 72 d5 06 08 90 d4
00000150 85 60 00 15 00 af 00 00 00 00 00 00 00 00 00 00
00000160 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
00000170 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
00000180 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
00000190 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
000001A0 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
000001B0 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
000001C0 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
000001D0 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
000001E0 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
000001F0 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
00000200 00 00 00 00 00

00000000 16 03 03 00 7a 02 00 00 76 03 03 82 f4 4b ce
00000010 b3 46 18 0f 31 0b 53 1f 4d a0 e6 17 07 3a 83
00000020 06 c0 4c a2 eb 2c a3 6f b3 c2 f8 20 f8 43 a8
00000030 05 41 47 7e 53 47 37 ad 39 78 32 5a f7 88 ae
00000040 64 77 d6 51 e6 e4 ac ef 03 26 6a a2 13 02 00
00000050 2e 00 33 00 24 00 1d 00 20 85 51 b9 c0 6e b7
00000060 4e 79 54 6a dc f5 c2 5b 7d 0b 5e 59 a7 50 a4
00000070 58 20 c8 6a d6 58 7b 55 33 00 2b 00 02 03 04
00000080 22 23 28 21 17 23 23 18 44 2c 2d 1e 2c 2c

00000205 14 03 03 00 01 01 17 03 03 00 45 86 84 73 0f 16
00000215 12 22 39 31 bb 38 39 3d 02 13 d0 b0 e0 dd 0a a2
00000225 ea 6b 90 8f ab 28 f1 3c 4e f8 f8 be ba 27 d2 67
00000235 e8 e4 2e 71 28 62 13 11 7d fb a1 58 fc 0c 1d 5b
00000245 da 7c 91 3f 6d 9f bb 1d 6c 0b 67 ce 18 23 b9 d8
00000255 17 03 03 00 29 ae d9 ce dc e1 eb c5 15 ed ab 31
00000265 09 28 e9 65 87 98 4a 7a 76 e9 4b 19 f7 8a 12 d9
00000275 07 f3 87 8d 9d e1 dc 6e af 3e 52 bd 94 81 17 03
00000285 03 00 2c ff 1d 93 26 f3 b8 64 16 37 40 d9 4b 87
00000295 56 6a 20 78 46 14 01 12 fd 1e f8 82 8e 01 44 53
000002A5 b2 e6 c8 01 ca fe 25 86 d4 b4 39 1d 18 85 f9
000002B4 17 03 03 00 1e 2d 05 11 4e c9 af f5 05 89 07 05
000002C4 27 55 03 a0 0b 74 35 c7 25 d9 03 89 4e 97 87 70
000002D4 a0 ba 26 17 03 03 00 39 31 66 19 54 9b d1 e9 c5
000002E4 f4 bc 2f 43 ff 0d 91 be e8 11 ef f9 90 35 07 7e
000002F4 4c de 3e 05 b5 b6 2a 34 7b 83 9d b6 48 32 e5 a9
00000304 17 12 f2 94 3c a2 27 2c 75 da 77 8f 98 71 6a 1d
00000314 47

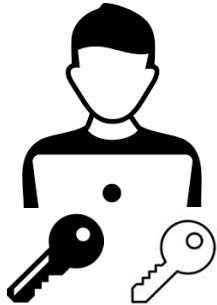
000010CE 17 03 03 02 45 f8 f4 1d 68 b1 7e e5 a2 c6 1f ec
000010DE 2a 27 d0 d9 cb 6f 5d 4a 31 7b d4 54 43 e2 8f e7
000010EE e9 d0 d7 1e 8b 4f da 2a 8e 41 26 91 2a 27 d2 bc
000010FE a9 de 8f 07 57 b5 72 01 11 2f 42 c4 e9 8f 41 80
0000110E 29 84 2b b7 8b db 8a a6 63 19 70 a3 c8 7c 28 85
0000111E 17 00 86 d0 ea 02 30 f3 1f 8e 6b a0 c9 19 77 de
0000112E 31 4f 61 e3 d8 4b 8e dc c6 c7 f2 32 fa 70 f0 e1
0000113E bb af 9c 79 e0 a9 f1 50 6c da d7 e2 36 eb 0b bb
0000114E 09 f2 a3 7d a0 13 46 2e 3a 81 5c 77 d4 05 c5 2e
0000115E 6f ba 65 49 52 1d f5 0b 1b 7d db c5 f9 1d ab ec
0000116E 39 d3 40 0a 4b e3 f6 80 56 e2 eb c5 d3 b8 df 79
0000117E b5 8f 07 48 61 30 a8 19 08 00 f5 51 d1 20 a6 b8
0000118E 29 92 52 ae 46 89 ce 2d 43 a9 b1 ec 62 0f 69 f2
0000119E ff 34 67 5f 92 94 9f 9a 3d e6 36 0c 73 b9 8f 5a
000011AE 2c bb 91 24 fd 94 8f c4 72 f2 41 6a 49 86 f7 aa
000011BE 8e 17 16 c6 0e 48 92 cf 7b b3 a5 74 ee b6 f4 f4
000011CE cb 39 a6 f0 e1 15 a0 46 52 1c ab b9 ab ea d9 82
000011DE fb a2 77 08 3d 05 65 20 18 7f e3 dd 44 f4 2b 38
000011EE e7 23 9e 7f c6 29 83 dd 0b f0 e4 d0 b7 a9 fe 18
000011FE 83 8f 7f cc 9f 88 42 df ad a2 41 76 8f 16 3e 4e
0000120E 9f ea 72 24 c0 92 fd f0 b8 b3 05 2b f2 97 f4 6b

..... ..E.s..
."91.89=
.k...(< N....'.g
...q(b.. }..X...[
..|.?.m... l.g..#..
.....)....1
..(e..Jz v.K.....
.....n .>R.....
...,...&. .d.7@.K.
Vj xF...DS
.....%. ..9....
.....~. N.....
'U...t5. %...N..p
..&....9 1f.T.....
../C.....5.~
L.>...*4 {...H2..
....<.' , u.w..qj.
G
....E... h.~.....
*!'...iJJ 1{.TC...
.....0.* .A&.*'..
.....W.r. ./B...A.
)..... c.p.|(.
.....0. ...k...w.
10a...K.. ...2.p..
...y...P l...6...
...}.F. :.\w....
o.eIR... }.....
9.@.K... V.....y
...Ha0... ..Q...
)..R.F.- C...b.i..
.4g..... =.6.s..Z
,..\$. r.AjI...
.....H.. {...t....
.9.....F R.....
..w.=.eD.+8
.#...)).....
..w...B. ..Av...8N
..r\$.+..k

PRIMER ON SECURING THE INTERNET COMMUNICATION

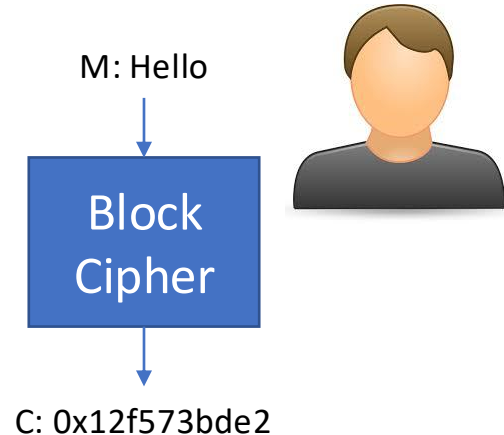
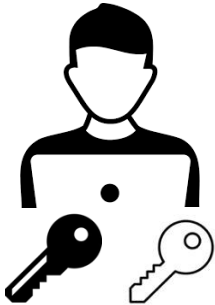
PUBLIC KEY CRYPTOGRAPHY

- The key idea
 - Asymmetric key cryptography
 - Use two different keys for encryption and decryption
 - Public key: share to others, only can encrypt a message
 - Private key: do not share, can encrypt and decrypt
 - What is possible?



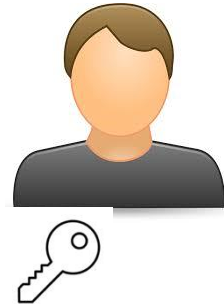
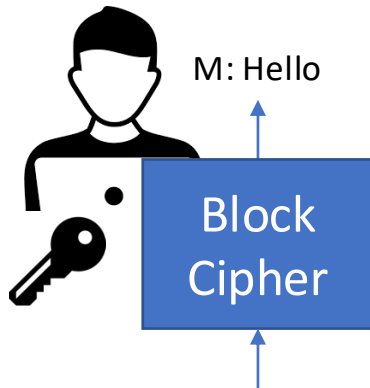
PUBLIC KEY CRYPTOGRAPHY

- The key idea
 - Asymmetric key cryptography
 - Use two different keys for encryption and decryption
 - Public key: share to others, only can encrypt a message
 - Private key: do not share, can encrypt and decrypt
 - What is possible?



PUBLIC KEY CRYPTOGRAPHY

- The key idea
 - Asymmetric key cryptography
 - Use two different keys for encryption and decryption
 - Public key: share to others, only can encrypt a message
 - Private key: do not share, can encrypt and decrypt
 - What is possible?



PUBLIC KEY CRYPTOGRAPHY

- The key idea
 - Asymmetric key cryptography
 - Use two different keys for encryption and decryption
 - Public key: share to others, only can encrypt a message
 - Private key: do not share, can encrypt and decrypt
 - What is possible?
 - No one can decrypt a ciphertext unless they have the private key
 - We do not need to share the private key to anyone else
 - We share public key that can only encrypt the message

PUBLIC KEY CRYPTOGRAPHY: ADVANTAGE

- Key exchange complexity
 - Each person shares their public key to everybody
 - But they do not share their private key
 - We need $O(N)$ keys
- Benefit: it scales!
 - Suppose we have a crypto conference with 400 folks
 - Symmetric key crypto: we need $400 \times 399 / 2$ keys for secure comm.
 - Asymmetric key crypto: we only need 400 public-private key pairs

PUBLIC KEY CRYPTOGRAPHY: RSA

- RSA (Rivest, Shamir, Adleman)
 - A popular public key cryptography algorithm
 - It exploits the difficulty of prime factorization
 - To break RSA, an adversary *needs to solve the prime factorization of a large number*

RSA

- Asymmetric key cryptography
 - Public key: e and N
 - Private key: d
- Key selection:
 - Choose two *large prime number*, p and q
 - Public key:
 - Set $N = pq$
 - Choose e as a coprime of $\phi = (p-1)(q-1)$
 - Private key:
 - Find d that satisfies $de \equiv 1 \pmod{\phi}$, $d \equiv e^{-1} \pmod{\phi}$

RSA

- Key selection:
 - Choose two large prime number, p and q
 - Public key:
 - Set $N = pq$
 - Choose e (e.g., 65537) as a coprime of $\phi = (p-1)(q-1)$
 - Private key:
 - Find d that satisfies $de \equiv 1 \pmod{\phi}$, $d \equiv e^{-1} \pmod{\phi}$
- Security
 - Concern: can an adversary guess the private key from the public key?
 - To do such an attack, the attacker needs to find ϕ
 - But we choose p and q as a large prime number; thus, it is difficult

RSA ENCRYPTION

- Suppose we have
 - Public key: e, N
 - Message: M
 - Ciphertext: $M^e \bmod N$

RSA DECRYPTION

- We have
 - Public key: e, N
 - Message: M
 - Ciphertext: $M^e \bmod N$
- Suppose we also have
 - Public key: e, N
 - Private key: d (that satisfies $ed = 1$)
 - Ciphertext: $C = M^e$
 - Plaintext: $C^d \bmod N$
 - $= (M^e)^d \bmod N$
 - $= M^{ed} \bmod N$
 - $= M \bmod N$ (N is a really large prime, so mostly it's M)

HOW COULD IT GO WRONG – SCHNEIER'S

HOW COULD IT GO WRONG

- Hypothesis
 - People care less about this secure mechanism
 - Devices generate keys badly

HOW COULD IT GO WRONG

- Hypothesis
 - People care less about this secure mechanism
 - Devices generate keys badly
- How would we evaluate this hypothesis?
 - Ask vendors ... Good luck
 - Ask the Internet operators ... Good luck
 - Purchase all devices and audit them ... You're my friend, a billionaire
 - Measurement at scale

MEASUREMENT AT SCALE

- Problem
 - IPv4 addresses, which is roughly 4.3 billion ones
 - nmap-based scanners
 - Open a connection, keep state per host, wait for timeouts, ...
 - The Internet scale scanning would take weeks... (why this is a problem?)
- ZMap
 - Stateless: no need to keep the state; use TCP SYN
 - Random permutation: no DDoS on a sub-networks
 - Result: ~45-min for scanning the entire IPv4 space for a port number!
- Censys
 - Scan the Internet and publish a database for studies (why this is nice?...)

CENSYS FINDINGS

- Industrial control systems
 - SCADA (Supervisory control and data acquisition) systems
 - No authentication while communicating over the Internet
 - No proper security protection mechanisms

Country	Modbus Devices	
United States	4723	24.7%
Spain	1,448	7.58%
Italy	1,220	6.39%
France	1,149	6.02%
Turkey	884	4.63%
Canada	822	4.30%
Denmark	732	3.83%
Taiwan	682	3.57%
Europe	615	3.22%
Sweden	567	2.97%
Total	12,842	67.23%

Table 4: **Top Countries with Modbus Devices** — We identified Modbus hosts in 117 countries, with the top 10 countries accounting for 67% of the total costs, and nearly one-quarter of all Modbus hosts we identified are located in the United States.

Device Type	Count
Modbus Ethernet Gateway	1,440
Programmable Logic Controller	1,054
Solar Panel Controller	635
Water Flow Controller	388
Power Monitor/Controller	158
Touchscreen System Controller	79
SCADA Processor/Controller	99
Environment/Temperature Sensor	10
Cinema Controller	5
Generic Modbus Device	28,750

Table 5: **Modbus Devices** — We used Censys to categorize publicly available industrial control systems that support the Modbus protocol.

CENSYS FINDINGS – CONT'D

- Heartbleed, Poodle, and SSLv3
 - Heartbleed (<https://heartbleed.com>): CVE-2014-0160
 - An implementation error in OpenSSL
 - Patched quickly once known to public, but...
 - Poodle
 - A fundamental flaw in the SSLv3 protocol
 - SSL 3.0 has been disabled immediately

Vulnerability	Alexa	IPv4	IPv4 Trusted
Heartbleed	1.16%	0.96%	0.19%
SSLv3 Support	46.0%	55.8%	34.7%
SSLv3 Only	0.05%	2.9%	0.07%

Table 6: **Heartbleed and SSLv3**—We show a breakdowns for the Heartbleed vulnerability and SSLv3 support for HTTPS hosts in the IPv4 address space and the Alexa Top 1 Million.

HOW COULD IT GO WRONG – ANDERSON'S

A LARGE-SCALE MEASUREMENT ON TLS AND SSH SERVERS

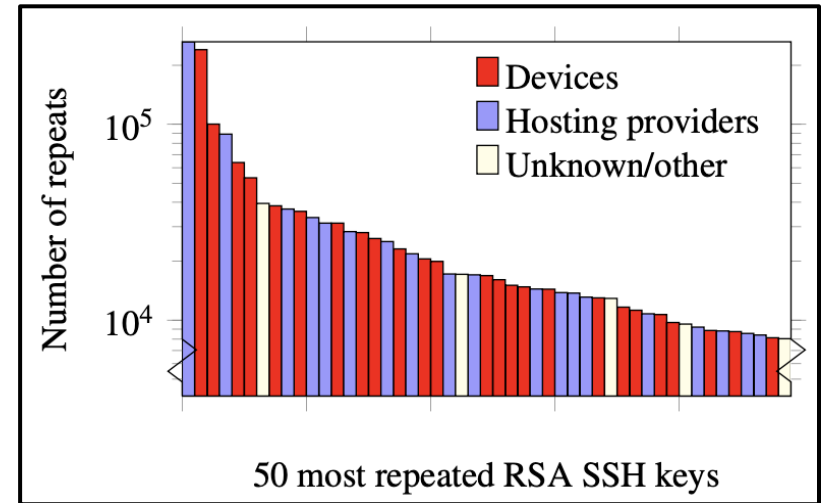
- *Systematic* measurement at scale
 - Scan all of IPv4 on port 443 (TLS) and port 22 (SSH)
 - Collect every public key available (or offered)
- Resulting data
 - 5.8 million TLS certificates and 6.2 million SSH host keys

TLS AND SSH HOSTS SHARE KEYS

- Main observation
 - 61% of TLS hosts and 65% of SSH hosts served the same key as another host

TLS AND SSH HOSTS SHARE KEYS – SANITY CHECKS

- Main observation
 - 61% of TLS hosts and 65% of SSH hosts served the same key as another host
- “Shared” does not mean “vulnerable”
 - Many IP addresses owned by a few organizations
 - Hosting providers
 - Load balancers
 - CDN front-ends
 - ...
 - Distinct TLS certificates
 - Reissued for the same organization



THE FIRST SURPRISE: REPEATED KEYS

- The keys the owner did not choose
 - 5.23% of the TLS hosts use manufacturer-default certificates or keys
 - Those are in firmware – the same products have the same key(s)
 - Buy one device, and then you have the world
 - 0.34% of the TLS hosts served repeated keys (98% are self-signed)
 - 9.60% of the SSH hosts served repeated keys

THE SECOND SURPRISE: REPEATED PRIMES

- The GCD trick
 - Two public keys N1 and N2
 - $N1 = p \times q1$
 - $N2 = p \times q2$
 - $\text{GCD}(N1, N2) = \text{GCD}(pq1, pq2) = p$
 - *Note: computing GCD takes only an eye-blink time*
 - Now...
 - $q1 = N1 / p$, and then $\phi1 = (p - 1)(q1 - 1)$
 - $q2 = N2 / p$, and then $\phi2 = (p - 1)(q2 - 1)$
 - $d1 == e^{-1} \pmod{\phi1}$
 - $d2 == e^{-1} \pmod{\phi2}$... (note that e is the known exponent)

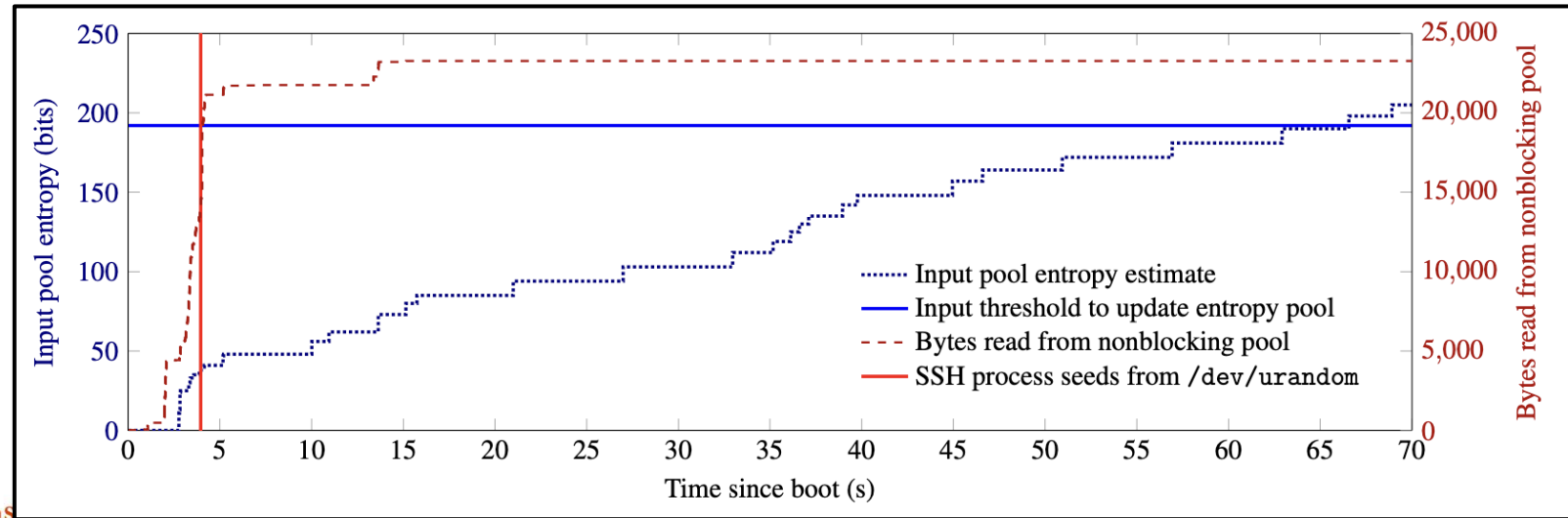
This Does Not Break RSA; This Does Not Factor Anything

THE SECOND SURPRISE: REPEATED PRIMES

- Factorable RSA keys
 - Obtain private keys for 0.40% of the TLS certificates; 0.5% of the TLS hosts
 - Obtain 0.02% of the RSA SSH host keys; 0.027% of the RSA SSH hosts
 - These factorable keys are:
 - System-generated certificates
 - SSH host keys used by embedded devices, e.g., routers, firewalls...

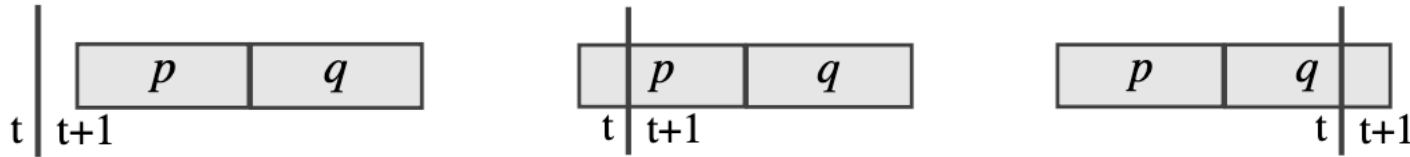
THE ROOT-CAUSE OF THE VULNERABILITIES

- Weak entropy and the Linux RNG
 - Linux has entropy sources weakened under certain operating conditions
 - It uses the Nonblocking pool entropy until Input pool reaches to a certain threshold
 - The figure shows (red line) the time when the OpenSSH reads its initial PRNG
 - OpenSSH reads the PRNG before the system is ready for the secure use



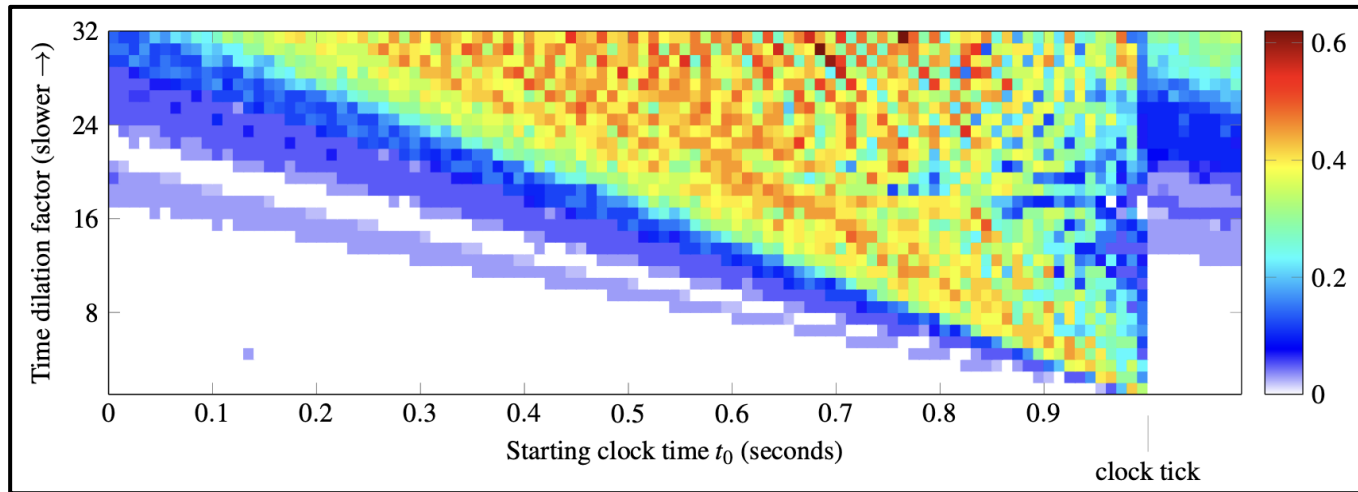
THE ROOT-CAUSE OF THE VULNERABILITIES

- OpenSSH RSA key generation algorithm
 - Suppose we generate p and q pairs across many systems
 - (Left) If the t is the same while computing p and q , it will generate the same key
 - (Middle) If the clock ticks while generating p , then p and q do not share a factor
 - (Right) If the clock ticks while generating q , then p will be the same, but not q



THE ROOT-CAUSE OF THE VULNERABILITIES

- OpenSSH RSA key generation algorithm
 - Suppose we generate p and q pairs across many systems
 - (Left) If the t is the same while computing p and q , it will generate the same key
 - (Middle) If the clock ticks while generating p , then p and q do not share a factor
 - (Right) If the clock ticks while generating q , then p will be the same, but not q
 - Empirical analysis



WHY IS THIS THE ANDERSON'S PROBLEM?

THE FIX WAS KNOWN, BUT WHO FIXES IT?

- None of the security fixes are research problems
 - Do not generate keys on first boot
 - Include a per-device factory random seed
 - Mix in a device serial number
 - ...

THE FIX WAS KNOWN, BUT WHO FIXES IT?

- None of the security fixes are research problems
 - Do not generate keys on first boot
 - Include a per-device factory random seed
 - Mix in a device serial number
 - ...
- Anderson's problem
 - Who could fix it – the device manufacturer, and the OS/library developers
 - Who pays for this – the device *owner*
 - What's the problem
 - The owner buys a \$100 router does not distinguish a properly seeded device
 - No premium in having such security
 - The vendors are not responsible for the security problem(s)

Thank You!

Sanghyun Hong

<https://secure-ai.systems/courses/Sec-Grad/current>



Oregon State
University



TRUE AI
Trustworthy and Responsible AI